

Gruppenaufgabe 1 | Ransomware-Erkennung und -Analyse

Szenario

Die «CyberShield AG», ein IT-Sicherheitsdienstleister mit Sitz in Winterthur, betreut über 40 KMU-Kunden in der Deutschschweiz. In den letzten drei Monaten haben zwei Kunden schwere Ransomware-Angriffe erlitten, obwohl beide über Antivirensoftware verfügten. Als internes Analyseteam der CyberShield AG sollen Sie die Angriffe rekonstruieren, die eingesetzten Erkennungsmethoden bewerten und ein verbessertes Erkennungskonzept für die Kundenbasis entwickeln.

Lernziele

Nach Bearbeitung dieser Aufgabe können Sie:

- Verschiedene Ransomware-Erkennungsmethoden (Signatur, Verhalten, IoC) analysieren und deren Stärken sowie Schwächen bewerten.
- Indicators of Compromise auf eine konkrete Angriffssituation anwenden und relevante Indikatoren identifizieren.
- Ein mehrstufiges Erkennungskonzept entwickeln, das verschiedene Erkennungsmethoden sinnvoll kombiniert.

Arbeitsauftrag

Analysieren Sie in Ihrer Kleingruppe, warum die bestehende Antivirensoftware die Ransomware-Angriffe bei beiden Kunden nicht verhindern konnte. Bewerten Sie die Erkennungsmethoden Signaturerkennung, Verhaltensanalyse, IoC-Analyse und Netzwerkmonitoring hinsichtlich ihrer Wirksamkeit. Entwickeln Sie ein mehrstufiges Erkennungskonzept, das mindestens drei Erkennungsebenen kombiniert.

Ergebnis

Bereiten Sie eine Kurzpräsentation vor (max. 5 Minuten), in der Sie die Schwachstellen der bisherigen Erkennung aufzeigen und Ihr mehrstufiges Erkennungskonzept mit Begründung der gewählten Ebenen vorstellen.

Musterlösung A | Gruppenaufgabe 1 | Ransomware-Erkennung und -Analyse

Ansatz: Strukturiert-analytisch

1. Ausgangslage und Fragestellung

Zwei KMU-Kunden der CyberShield AG wurden trotz vorhandener Antivirensoftware Opfer von Ransomware-Angriffen. Dies wirft die zentrale Frage auf: Warum hat die bestehende Erkennung versagt, und wie kann ein robusteres Erkennungskonzept aussehen?

2. Analyse des Erkennungsversagens

Warum hat die Antivirensoftware versagt?

Klassische Antivirensoftware basiert primär auf Signaturerkennung. Diese Methode vergleicht Dateien mit einer Datenbank bekannter Schadsoftware-Signaturen. Sie versagt in folgenden Szenarien:

Szenario	Erklärung
Neue Ransomware-Variante	Die Signatur der Schadsoftware ist noch nicht in der Datenbank erfasst («Zero-Day»).
Polymorphe Ransomware	Die Schadsoftware verändert ihren Code bei jeder Infektion, sodass keine feste Signatur existiert.
Dateilose Angriffe	Ransomware nutzt legitime Systemwerkzeuge (z. B. PowerShell) und hinterlässt keine klassische Schaddatei.
Verschleierung	Angreifer packen die Ransomware in verschlüsselte Container, die der Scanner nicht analysieren kann.

Die Analyse zeigt: Signaturerkennung allein ist als Schutzmassnahme gegen moderne Ransomware unzureichend. Sie erkennt nur bekannte Bedrohungen und ist gegen neuartige oder verschleierte Angriffe wirkungslos.

3. Bewertung der Erkennungsmethoden

Methode	Stärken	Schwächen	Wirksamkeit gegen moderne Ransomware
---------	---------	-----------	--------------------------------------

Signaturerkennung	Zuverlässig bei bekannten Varianten; schnell; ressourcenschonend	Versagt bei neuen, polymorphen und verschleierte Varianten	Gering als alleinige Methode
Verhaltensanalyse	Erkennt unbekannte Varianten anhand verdächtiger Aktionen (z. B. massenhafte Verschlüsselung)	Potenzial für Fehlalarme; erfordert Rechenleistung	Hoch – erkennt auch Zero-Day-Angriffe
IoC-Analyse	Ermöglicht Erkennung auf Basis bekannter Angriffsindikatoren (Hashes, IPs, Domänen)	Erfordert aktuelle Threat-Intelligence-Feeds; reaktiv, nicht proaktiv	Mittel – gut als Ergänzung
Netzwerkmonitoring	Erkennt ungewöhnliche Datenströme, Kommunikation mit C2-Servern, laterale Bewegung	Erfordert Baseline-Definition; kann bei verschlüsseltem Verkehr eingeschränkt sein	Hoch – erkennt Ausbreitung

4. Mehrstufiges Erkennungskonzept

Das vorgeschlagene Konzept kombiniert vier Erkennungsebenen in einem «Defense-in-Depth»-Ansatz:

Ebene 1: Perimeterschutz (E-Mail- und Web-Gateway)

- Filtert bekannte Phishing-E-Mails, schädliche Anhänge und kompromittierte URLs bereits am Netzwerkrand.
- Nutzt Signaturerkennung und URL-Reputation in Kombination.
- Wirkung: Blockiert den häufigsten Angriffsvektor (Phishing) an der Eingangstür.

Ebene 2: Endpoint Detection and Response (EDR)

- Überwacht jeden Endpunkt mittels Verhaltensanalyse in Echtzeit.
- Erkennt verdächtige Aktionen wie massenhafte Dateiverschlüsselung, Registrierungsänderungen oder Rechteerweiterung.
- Bei Erkennung wird der Endpunkt automatisch isoliert (Containment).
- Wirkung: Erkennt auch unbekannte Ransomware-Varianten und stoppt sie auf dem Endgerät.

Ebene 3: Netzwerkmonitoring mit SIEM

- Korreliert Sicherheitsereignisse aus allen Quellen (Firewall, EDR, Server-Logs) in einem zentralen SIEM-System.
- Erkennt laterale Bewegung, ungewöhnliche Datenströme und Kommunikation mit bekannten Command-and-Control-Servern.
- Wirkung: Erkennt die Ausbreitung von Ransomware im Netzwerk, selbst wenn einzelne Endpunkte kompromittiert wurden.

Ebene 4: Threat-Intelligence-Integration

- Automatischer Abgleich aller Netzwerk- und Endpunktdaten mit aktuellen Threat-Intelligence-Feeds.
- IoC-Daten (Hashes, IP-Adressen, Domänen) werden kontinuierlich aktualisiert.
- Wirkung: Beschleunigt die Erkennung bekannter Angriffskampagnen und liefert Kontext für die forensische Analyse.

5. Implementierungsempfehlung für KMU-Kunden

Ebene	Lösung	Geschätzte Kosten/Jahr	Priorität
1 – Perimeter	Cloud-basierter E-Mail-Filter	CHF 5–10/Benutzer/Monat	Sofort
2 – Endpoint	EDR-Lösung (z. B. CrowdStrike, SentinelOne)	CHF 8–15/Endpunkt/Monat	Sofort
3 – Netzwerk	Managed SIEM Service	CHF 500–2000/Monat	Quartal 1
4 – Threat Intel	Integration in EDR/SIEM (meist inkludiert)	Inkludiert	Quartal 1

6. Fazit

Die beiden Angriffe auf CyberShield-Kunden zeigen, dass eine einzelne Erkennungsebene nicht ausreicht. Moderne Ransomware umgeht klassische Signaturerkennung gezielt. Nur ein mehrstufiges Konzept, das Verhaltensanalyse, Netzwerküberwachung und aktuelle Bedrohungsinformationen kombiniert, bietet einen wirksamen Schutz. Die CyberShield AG sollte dieses Konzept als Standard-Service-Paket für alle KMU-Kunden anbieten.